COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

# Security+ 2.4 · Wireless Attacks

Mestre CyberSec · **Lesson 2.4 — Wireless Attacks** (7:55) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

**Executive Lesson Summary:** Wi-Fi attacks: deauthentication/deassociation (desconecta clientes mandando frame falsificado — aí o cliente reconecta no evil twin); evil twin (AP falso com SSID igual); RF jamming (corta o rádio inteiro); bluesnarfing/bluejacking (Bluetooth). Defesa: WPA3/SAE, detectar AP clone

## 💡 Key Exam Highlights & Critical Concepts

- Evil twin: AP falso com a MESMA SSID — captura o handshake
- Deauth: desconecta clientes pra eles caírem no evil twin
- WPA3/SAE protege o handshake contra captura de senha

## 🎯 Exam Tips & Typical CompTIA Scenarios

- 'fake access point mimics legitimate one' = evil twin
- 'disconnects wireless clients' = deauthentication attack

## 🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.4 — Wireless Attacks)

**Why is this advanced coverage required for SY0-701?:** Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

**• Deauthentication Attack (Deauth)**

A wireless DoS attack that sends spoofed 802.11 management frames to disconnect clients from a legitimate AP, forcing them to reconnect — often to an attacker-controlled evil twin.

⚠ ***Exam Trap:*** *If the question says 'disconnects wireless clients' or 'spoofed management frame,' it is a deauthentication attack. Remember: deauth = management frame, not data frame.*

**• Evil Twin (N/A)**

A rogue wireless access point configured with the same SSID as a legitimate network to lure clients into associating, enabling credential theft (handshake capture) and man-in-the-middle attacks.

⚠ ***Exam Trap:*** *Exam trigger — 'fake access point that mimics a legitimate one' = evil twin. Combine with deauth: deauth kicks clients off, evil twin catches them when they reconnect.*

**• RF Jamming (Radio Frequency Jamming)**

A denial-of-service attack that emits strong radio frequency noise on the same spectrum as the wireless network, overwhelming the signal and preventing legitimate communication.

⚠ ***Exam Trap:*** *Jamming = DoS at Layer 1 (physical). Distinguish from deauthentication, which works at Layer 7 using legitimate management frames. Both are DoS, but jamming is raw RF interference.*

**• Bluesnarfing (N/A)**

An attack that exploits Bluetooth vulnerabilities to gain unauthorized access to a device and steal data such as contacts, calendars, and messages without the user's knowledge.

⚠ ***Exam Trap:*** *Bluesnarfing = DATA theft (snarf = steal). Do not confuse with bluejacking, which only sends unsolicited messages. If the question mentions stolen data over Bluetooth, it is bluesnarfing.*

**• Bluejacking (N/A)**

Sending unsolicited messages or business cards to nearby Bluetooth-enabled devices as a Bluetooth DoS or spam technique — it does not involve data theft.

⚠️ ***Exam Trap:*** *Bluejacking = unsolicited MESSAGES (jacking = jab). No data is taken. Compare to bluesnarfing (data theft) and bluebugging (full remote control of the device).*

**• WPA3 with SAE (Simultaneous Authentication of Equals) (WPA3 / SAE)**

The modern Wi-Fi security standard replacing WPA2's 4-way handshake with SAE, a Dragonfly-based key exchange that resists offline dictionary attacks even if the handshake is recorded.

⚠️ ***Exam Trap:*** *Exam trigger — 'protects against offline brute-force / handshake capture' = WPA3/SAE. SAE uses a password-authenticated key exchange (PAKE); each session derives a unique key.*

**• Rogue Access Point (Rogue AP)**

Any unauthorized wireless access point connected to the corporate network, intentionally or accidentally installed by an insider, creating a backdoor into the wired infrastructure.

⚠️ ***Exam Trap:*** *Rogue AP ≠ Evil Twin. Rogue AP = plugged into the corporate LAN without approval (insider threat). Evil Twin = wireless mimicry with same SSID to attack clients. The exam distinguishes these carefully.*

**• 4-Way Handshake**

The WPA/WPA2 authentication process where the AP and client exchange four EAPOL messages to derive the same Pairwise Transient Key (PTK) for encrypted traffic.

⚠️ ***Exam Trap:*** *Exam focus: the 4-way handshake can be captured by an evil twin and cracked offline with a dictionary attack — this is precisely why WPA3/SAE was introduced.*

## 🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

### 📌 Evil Twin vs. Rogue Access Point

🏠 **Real-World Analogy:** A Rogue Access Point is like an employee sneaking a cheap home Wi-Fi router into the office, plugging it beneath their desk into a corporate Ethernet port to bypass network monitoring. An Evil Twin is an identity theft trap: a fraudster sets up a counterfeit coffee kiosk right outside an authentic Starbucks, branding it with the exact same 'Starbucks_Guest' SSID name and broadcasting with higher signal power so customer smartphones automatically roam onto the imposter network.

🔍 **Root Cause & Background:** Wireless clients prioritize known SSIDs based on signal strength (RSSI), blindly associating with the loudest access point. For rogue APs, unauthenticated switch ports lacking 802.1X allow employees to bridge untrusted wireless gear directly into the internal LAN.

🛡️ **GRC Auditor Perspective:** Deploy enterprise WIPS (Wireless Intrusion Prevention System) to continuously scan RF bands and contain unauthorized BSSIDs; mandate 802.1X authentication with digital certificates (EAP-TLS) and enable switch Port Security.

⚠️ **How CompTIA Tests This:** Trigger: 'unauthorized wireless device connected to a wired switch by an insider' -> Rogue Access Point. Trigger: 'fraudulent AP broadcasting an identical SSID with stronger signal strength to intercept traffic' -> Evil Twin.

### 📌 Deauthentication Attack & RF Jamming

🏠 **Real-World Analogy:** A Deauthentication Attack is like a prankster grabbing a megaphone outside an auditorium, mimicking the director's voice and shouting: 'Meeting canceled, everyone evacuate immediately!'. Confused attendees drop their connections; the attacker then points them toward the counterfeit auditorium next door (the Evil Twin). RF Jamming is like sounding a deafening air horn right in the room: electromagnetic noise completely drowns out speech, making wireless communication physically impossible.

🔍 **Root Cause & Background:** In legacy WPA2/802.11 architectures, management frames (Deauthentication/Disassociation) lack cryptographic signing, allowing threat actors to forge the AP's source MAC address. RF Jamming exploits the physical open-air medium by emitting high-power electromagnetic noise across standard wireless spectra.

🛡️ **GRC Auditor Perspective:** Enforce IEEE 802.11w Protected Management Frames (PMF) which cryptographically signs management frames; monitor spectrum analytics in the WIPS to detect and alert on localized intentional RF jamming.

⚠️ **How CompTIA Tests This:** Trigger: 'spoofed frames sent to force clients to disconnect and capture handshakes' -> Deauthentication Attack (Defense: 802.11w / PMF). Trigger: 'intentional radio frequency noise causing Denial of Service' -> RF Jamming.

### 📌 WPA2 vs. WPA3 (SAE & Forward Secrecy)

🏠 **Real-World Analogy:** WPA2-Personal relies on a Pre-Shared Key (PSK) where an attacker recording a device's initial handshake (the 4-way EAPOL exchange) can take the packet capture home and run billions of offline dictionary guesses without ever touching the network again. WPA3 eliminates this using SAE (Simultaneous Authentication of Equals / Dragonfly handshake): an active, zero-knowledge mathematical exchange where passive packet sniffers cannot crack keys offline. Furthermore, SAE provides Perfect Forward Secrecy, ensuring past intercepted sessions remain encrypted even if the master password is later compromised.

🔍 **Root Cause & Background:** The legacy WPA2 4-way handshake derives pairwise keys directly from a static passphrase without zero-knowledge proofs, exposing captured handshakes to high-speed offline dictionary cracking. WPA3 implements the Dragonfly handshake (SAE) and mandates 802.11w management frame protection.

🛡️ **GRC Auditor Perspective:** Enforce WPA3-Enterprise (or WPA3-Personal with SAE) across all access points; deprecate WPA2/WPA3 mixed transition modes that remain vulnerable to downgrade exploits; verify PMF enforcement.

⚠️ **How CompTIA Tests This:** Trigger: 'cryptographic feature in WPA3 protecting against offline password dictionary attacks' -> SAE (Simultaneous Authentication of Equals). Trigger: 'capturing four-way handshake packets to run a hashcat dictionary attack' -> WPA2 PSK vulnerability.

### 📌 WPS (Wi-Fi Protected Setup) Vulnerabilities

🏠 **Real-World Analogy:** WPS (Wi-Fi Protected Setup) PIN mode is like installing a 20-digit electronic lock on your front door, but adding a cheap 4-digit bicycle combination lock right beside it so guests can enter easily. An intruder ignores the complex main lock and cracks the trivial 4-digit lock in under two hours, unlocking the entire property.

🔍 **Root Cause & Background:** WPS simplifies onboarding using an 8-digit PIN. The protocol architecture verifies the first 4 digits separately from the last 3 digits (the 8th is a checksum). This design flaw reduces brute-force complexity from 100,000,000 possibilities to just 11,000 attempts, easily crackable within hours.

🛡️ **GRC Auditor Perspective:** Mandate the permanent disabling of WPS (Wi-Fi Protected Setup) across all enterprise and home-office access points in remote work security baselines.

⚠️ **How CompTIA Tests This:** Trigger: 'mechanism allowing device pairing via an 8-digit PIN susceptible to rapid brute forcing'. Answer: WPS. Recommended mitigation: Disable WPS.

## ⚡ QUICK-REFERENCE EXAM CHEAT SHEET

| Typical Exam Scenario / Practical Situation | Technical Concept & Target Answer |
|---|---|
| Attacker deploys a wireless access point configured with an identical SSID and stronger signal to harvest user credentials | **Evil Twin** |
| Unauthorized wireless AP connected to the corporate wired infrastructure by an employee without IT authorization | **Rogue Access Point** |
| Spoofed wireless management frames transmitted to disconnect legitimate users and force reconnection to a malicious AP | **Deauthentication Attack** |
| Deliberate radio frequency interference overwhelming wireless frequencies to cause complete service disruption | **RF Jamming** |
| WPA3 handshake mechanism that prevents offline dictionary and rainbow table cracking against pre-shared keys | **SAE (Simultaneous Authentication of Equals)** |
| Standard that cryptographically signs management frames to prevent spoofing and deauthentication attacks | **IEEE 802.11w / PMF (Protected Management Frames)** |

## ✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

### QUESTION 1 · EXAM SCENARIO

**A SOC analyst reviews wireless controller logs and sees hundreds of spoofed 802.11 management frames arriving with the MAC address of the legitimate corporate AP, each addressed to a different client station. Seconds later, several laptops associate to an access point that is not in the authorized inventory. Which attack technique best explains the sudden disconnections?**

**A)** A deauthentication flood that forces clients to drop their association so they reconnect to an attacker-controlled AP

**B)** RF jamming that saturates the channel and prevents any 802.11 frame from being decoded

**C)** Bluejacking that pushes unsolicited frames to nearby Bluetooth-enabled laptops

**D)** Passive capture of the 4-way handshake to derive the pairwise transient key

### QUESTION 2 · EXAM SCENARIO

**Users in the east wing report that their laptops show a strong wireless signal but cannot stay associated with any SSID, and even a personal mobile hotspot fails to work. A spectrum analyzer shows a sharply elevated noise floor across the 2.4 GHz and 5 GHz bands, with no decodable 802.11 frames in the affected area. Which type of attack is occurring?**

**A)** Deauthentication flood targeting the corporate controller

**B)** RF jamming that interferes with the radio frequency spectrum itself

**C)** Evil twin access point advertising the corporate SSID

**D)** Bluesnarfing of contact data from nearby mobile devices

### QUESTION 3 · EXAM SCENARIO

**Attendees at a conference connect to an SSID named ConfGuest that looks identical to the official network. The captive portal then asks for corporate email credentials. The network team later finds a second radio nearby with the same SSID, a stronger signal, a different BSSID, and a consumer-grade router as its hardware. Which attack is described?**

**A)** Deauthentication attack against the conference access points

**B)** Bluejacking through an unauthenticated Bluetooth pairing

**C)** Evil twin access point used to harvest credentials through a fake portal

**D)** RF jamming that forces clients onto a competing channel

**QUESTION 4 · EXAM SCENARIO**

**An employee reports that nothing unusual appeared on their phone, yet a security review later discovers that the contact list and calendar entries were copied from the device by someone standing nearby in the cafeteria. The device had Bluetooth enabled and paired with a personal headset earlier that day. Which Bluetooth attack most likely occurred?**

**A)** Bluejacking, which sends unsolicited business cards to nearby devices

**B)** Bluesnarfing, which illicitly extracts data such as contacts and calendar entries over Bluetooth

**C)** Deauthentication, which forges 802.11 management frames to break the pairing

**D)** RF jamming, which overwhelms the Bluetooth piconet with noise

**QUESTION 5 · EXAM SCENARIO**

**During a site walkthrough, several employees in the lobby show the security analyst unsolicited vCard and text messages that appeared on their phones over Bluetooth. The employees never accepted a pairing request, and forensic review confirms that no files or personal data left their devices. Which Bluetooth activity is this?**

**A)** Bluesnarfing of contact and calendar data

**B)** Evil twin impersonation of a mobile carrier hotspot

**C)** RF jamming of the Bluetooth piconet

**D)** Bluejacking, which sends unsolicited messages to discoverable devices

**QUESTION 6 · EXAM SCENARIO**

**An assessment shows that an attacker on the perimeter disconnects a wireless client, captures the WPA2-PSK 4-way handshake, takes it offsite, and runs an offline dictionary attack against the shared passphrase. Which change most directly removes the ability to perform that offline cracking attempt?**

**A)** Migrate the WLAN to WPA3 with Simultaneous Authentication of Equals

**B)** Disable SSID broadcast on all corporate access points

**C)** Enable MAC address filtering on the wireless controller

**D)** Reduce access point transmit power to shrink the coverage area

**QUESTION 7 · EXAM SCENARIO**

**After a wireless upgrade, an engineer notices that forged deauthentication frames from a test tool no longer drop connected clients, and the intrusion sensors log them as discarded. Which feature of the upgraded standard accounts for this behavior?**

**A)** Simultaneous Authentication of Equals

**B)** Wi-Fi Protected Setup push-button enrollment

**C)** Protected Management Frames, defined in 802.11w

**D)** Pre-shared key rotation on a fixed schedule

**QUESTION 8 · EXAM SCENARIO**

**A security team must detect unauthorized access points operating on the corporate campus, including devices that broadcast a corporate-looking SSID alongside legitimate infrastructure. Which control is most effective for this objective?**

**A)** Disabling SSID broadcast on all corporate access points

**B)** A wireless IPS that continuously compares detected radios against an authorized AP inventory

**C)** Enabling MAC address filtering on the wireless controller

**D)** Assigning static IP addresses to all corporate client devices

**QUESTION 9 · EXAM SCENARIO**

**Employees repeatedly connect to a fraudulent access point that clones the corporate SSID, and in some cases they type their domain credentials into a look-alike portal. Which control best enables client devices to reject the illegitimate AP during authentication, before any credentials are exposed?**

**A)** Hiding the corporate SSID from beacon frames

**B)** An allow-list of client MAC addresses on the wireless controller

**C)** WPA2-PSK with a strong passphrase rotated each month

**D)** WPA3-Enterprise with 802.1X/EAP-TLS and mandatory server certificate validation by clients

**QUESTION 10 · EXAM SCENARIO**

**An employee plugs a personal wireless router into an unused wall Ethernet jack to improve coverage in a conference room. The device broadcasts an SSID similar to the corporate network and hands out DHCP leases to nearby clients, bypassing the organization's wireless security controls. Which control most effectively prevents this device from granting network access?**

**A)** Enforce 802.1X port-based authentication with network access control on all switch access ports

**B)** Configure MAC address filtering on every switch access port

**C)** Disable SSID broadcast on the corporate access points

**D)** Enable WPA3-SAE on the corporate wireless network

## ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

**Question 1: Option A — A deauthentication flood that forces clients to drop their association so they reconnect to an attacker-controlled AP**

Deauthentication/deassociation attacks send forged 802.11 management frames using the legitimate AP's MAC address, causing clients to believe the AP terminated the session. Victims automatically reconnect, which is exactly what makes this attack the standard precursor to an evil twin. RF jamming corrupts the medium with noise instead of valid management frames, bluejacking is a Bluetooth messaging nuisance that never disconnects Wi-Fi clients, and passively capturing a 4-way handshake collects material for offline cracking but does not disassociate anyone.

**Question 2: Option B — RF jamming that interferes with the radio frequency spectrum itself**

The elevated noise floor with no decodable 802.11 frames is the signature of RF jamming, which deliberately transmits energy on the same frequencies to deny the medium to every device in range, including legitimate APs and personal hotspots. A deauthentication flood still produces valid-looking management frames and only affects associated clients of a specific AP. An evil twin attracts clients rather than blocking the spectrum, and bluesnarfing is a Bluetooth data-theft technique unrelated to Wi-Fi radio noise.

**Question 3: Option C — Evil twin access point used to harvest credentials through a fake portal**

An evil twin is a rogue AP that copies a legitimate SSID (often with a stronger signal and a different BSSID) to lure clients into connecting to attacker-controlled infrastructure, where captive portals, DNS redirection, or on-path interception can capture credentials. Deauthentication only disconnects clients, bluejacking is Bluetooth spam, and jamming denies the medium rather than impersonating a network to collect user input.

**Question 4: Option B — Bluesnarfing, which illicitly extracts data such as contacts and calendar entries over Bluetooth**

Bluesnarfing is the unauthorized retrieval of information such as contacts, calendars, and messages from a Bluetooth-enabled device, typically when the device is left discoverable and vulnerable. Bluejacking only pushes unsolicited messages and does not extract data. Deauthentication is a Wi-Fi 802.11 concept, and RF jamming would cause a loss of connectivity and audible interference rather than a silent data copy.

**Question 5: Option D — Bluejacking, which sends unsolicited messages to discoverable devices**

Bluejacking is the practice of sending unsolicited messages, often vCards, to Bluetooth devices in range without taking any data from them. Because no data was extracted, bluesnarfing does not fit. Evil twin is a Wi-Fi access point impersonation technique, and RF jamming is deliberate interference, not messaging.

**Question 6: Option A — Migrate the WLAN to WPA3 with Simultaneous Authentication of Equals**

WPA3 uses SAE (Dragonfly), an authenticated key exchange that provides forward secrecy and is resistant to offline dictionary attacks on captured exchanges, so an attacker who records the handshake cannot grind passphrases offline. Disabling SSID broadcast, MAC filtering, and power reduction are weak obscurity or access controls that do not change the cryptographic exposure of WPA2-PSK.

**Question 7: Option C — Protected Management Frames, defined in 802.11w**

Protected Management Frames (802.11w), required in WPA3 and optional in WPA2, cryptographically protects unicast and broadcast management frames such as deauthentication and disassociation, so spoofed frames are rejected by clients and APs. SAE protects the authentication key exchange, WPS is a legacy enrollment convenience feature with known weaknesses, and PSK rotation does not protect management frames.

**Question 8: Option B — A wireless IPS that continuously compares detected radios against an authorized AP inventory**

A wireless IPS with an accurate baseline of authorized APs, BSSIDs, and channels can detect new or spoofed radios in real time and alert on rogue and evil twin devices. Disabling SSID broadcast hides the name but does not detect unauthorized radios, MAC filtering on the controller is a weak, spoofable access control, and static addressing does not address rogue APs that run their own DHCP service.

**Question 9: Option D — WPA3-Enterprise with 802.1X/EAP-TLS and mandatory server certificate validation by clients**

With 802.1X/EAP-TLS, the client and the authentication server mutually authenticate using certificates, so a client that validates the server certificate will fail the handshake against an evil twin that cannot present a trusted certificate. Hiding the SSID and MAC allow-lists are weak obscurity controls easily defeated, and a shared PSK is known by every user and by the attacker who harvests it, so it cannot distinguish a legitimate AP from a clone.

**Question 10: Option A — Enforce 802.1X port-based authentication with network access control on all switch access ports**

802.1X port-based authentication with NAC requires the connected device to authenticate to the network before any traffic is forwarded, so an unmanaged personal router plugged into a wall jack never obtains network access and cannot bridge wireless clients into the corporate LAN. MAC filtering and hidden SSIDs are easily bypassed, and WPA3-SAE only secures the corporate wireless link; it does nothing about a rogue AP attached to a wired port.